Tweetoscope

James Lemaitre - François Thievon - Louca Malerba

October 13, 2025

1 Secrets and Git

When developping applications involving the access to a distant service using a private API key or credentials, it is crucial to not leak them in a public repository for example.

It can be particularly tricky since even deleting the credentials in later versions of the code will not avoid other people to checkout older commits and read these tokens.

Hackers might use these tokens for different reasons, including accessing a private API which cannot be accessed by them (some API access can be linked to an account and thus access private data. It can be the case for example with the Spotify API which allows you to access your private data through your API key), stealing paid credits, abusing the access until the key gets banned for too many requests for example.

Instead of writing the tokens inside of the code as a variable, it is a better practice to write them in a config.properties file and add this file to the .gitignore.

For professional projects, specialized tools like Azure Key Vault can be used.

Other tools can allow developpers to scan the changes before comitting automatically, or to scan a repository to check if secrets are included within the code.